

Seguridad y Resiliencia

Minimización de datos, manejo de errores y puntos de control humano — Ecosistema de Atención al Cliente con Memoria (Estudio Contable)

Un flujo autónomo que atiende clientes en nombre de un estudio contable maneja datos personales y fiscales (Ley 25.326 de Protección de Datos Personales) y puede fallar de formas que afectan directamente a un cliente real. Este documento cubre las tres capas de resiliencia del sistema: qué datos circulan y cuáles se minimizan, qué pasa cuando algo falla, y dónde el sistema se detiene a esperar una aprobación humana.

1. Minimización de datos

Qué se envía a la IA (y qué no)

- Se envía: nombre/razón social, categoría fiscal, las últimas 3–5 consultas resumidas (no el historial completo de la cuenta), y el cuerpo del email nuevo.
- No se envía: CUIT completo salvo que la consulta puntual lo requiera (p. ej. pedido de un comprobante con ese dato); datos de otros clientes; el contenido completo de adjuntos no solicitados; ninguna credencial o clave de API dentro del prompt.
- El historial se resume a campos estructurados (fecha, categoría, resultado) en lugar de reenviar los emails completos anteriores — reduce tokens y superficie de exposición de datos a la vez.

Credenciales

- Las claves de Gmail, Airtable, Slack y Google Gemini viven únicamente en el Credential Store de n8n (cifrado), nunca hardcodedas en un nodo ni en el JSON exportado del flujo.
- El JSON de blueprint incluido en el repositorio no contiene ninguna clave real: los nodos de credenciales quedan referenciados por nombre, a completar por quien importe el flujo.
- En el video demo, cualquier pantalla que muestre el panel de credenciales o tokens se recorta o difumina antes de publicar.

2. Manejo de errores (resiliencia)

Reintentos y ruta de error

- El nodo de llamada a Gemini usa reintento automático de n8n: 3 intentos con backoff creciente (2s, 4s, 8s) antes de darse por vencido.
- Si los 3 reintentos fallan (timeout o error 5xx de la API), el flujo no se detiene en silencio: registra el error en la tabla Errores de Airtable (tipo, detalle, consulta relacionada) y dispara una alerta a Slack para el equipo.
- Si falta un dato obligatorio (p. ej. el email no matchea ningún cliente en Airtable), el flujo no fuerza una respuesta con datos incompletos: crea el registro como “No identificado” y lo deriva a revisión manual en lugar de improvisar con la IA.

Filtros de seguridad del flujo

Riesgo	Mitigación en este flujo
Loop infinito	El trigger de Gmail está en modo "From now on" y solo escucha la bandeja de entrada, nunca la de enviados: el propio email de respuesta del estudio no puede volver a disparar el flujo. Además, el nodo de reintento tiene un tope duro de 3 intentos.
Reprocesar el mismo email dos veces	Antes de crear un registro nuevo, se verifica por Message-ID si esa consulta ya existe en la tabla Consultas (idempotencia); si ya está en estado "Respondido", se descarta el duplicado.
Comparaciones de tipo incorrectas	Los campos numéricos (p. ej. Tiempo_Respuesta_Min) se tipan como Number tanto en Airtable como en las condiciones IF de n8n, para evitar comparaciones número-vs-texto que nunca disparan.
Prompt hardcodeado	Los datos variables (cliente, historial, consulta) se inyectan siempre por variable de n8n en tiempo de ejecución; el bloque fijo cacheado contiene solo instrucciones, nunca datos de un cliente puntual.

3. Human-in-the-Loop: el punto de control central

Ninguna respuesta llega al cliente sin que una persona del estudio la apruebe primero en Slack. Este es, por diseño, el punto más importante de todo el sistema: evita el “Efecto Metralleta” (que la IA le conteste en masa y sin supervisión a clientes reales con información fiscal potencialmente sensible).

- El borrador de la IA se manda al canal #aprobaciones-ia con botones Aprobar / Rechazar (Block Kit); el flujo queda en espera (nodo Wait) hasta recibir esa interacción.
- Aprobar: el flujo continúa y envía la respuesta por Gmail tal cual (o editada, si el aprobador modificó el texto antes de confirmar).
- Rechazar: el registro pasa a Estado = “Rechazado” y se marca para redacción manual; no hay reintento automático de la IA sobre una respuesta ya rechazada.
- Todo pasa por Airtable como registro auditable: quién aprobó, cuándo, y si el texto final coincidió con el borrador de la IA o fue editado.

Cumplimiento normativo

El estudio maneja datos personales y fiscales de clientes, alcanzados por la Ley 25.326 de Protección de Datos Personales (Argentina). El diseño del sistema se apoya en dos de sus principios centrales: minimización (sección 1) y control humano sobre decisiones que afectan a un titular de datos (sección 3, HITL). El HITL además funciona como control de calidad profesional: un contador sigue siendo responsable de lo que se comunica a nombre del estudio, la IA solo prepara el borrador.